Joint Authorization of Transformed Artifacts

Preserving multi-owner security obligations across transformation and final release

Authorization | Information Flow | Multi-Principal Systems | Provenance

Parsa Oryani | Sharif University of Technology | Research interests: secure and trustworthy agentic AI

Research thesis

Agent workflows increasingly combine artifacts governed by different owners: a private dataset, a licensed model output, a partner document, or a user-approved message. Individual approvals can remain valid while a later join, projection, aggregation, or audience change makes the combined release unauthorized.

This proposal develops a restricted authorization calculus for transformed artifacts. The checker should either produce a preservation witness for the exact output and recipients, explain the smallest conflicting obligations, or identify the owners whose approval must be renewed. The aim is useful release control without treating every transformation as automatically safe or forcing global reapproval after every change.

Problem and scope

The first version uses immutable, content-addressed artifacts; issuer-scoped predicates; typed recipients; and a small transformation algebra covering projection, filtering, approved joins, and fixed aggregates. A release permit is bound to the output digest, transformation witness, recipient set, and policy snapshot. Free-form summarization, open-ended code execution, global distributed revocation, and unverifiable external transforms are outside the initial guarantee.

The trusted base includes owner identity and assignment, reviewed policies, transformation semantics, artifact hashing, the checker, and the final release gate. Provenance supplies evidence about derivation but does not by itself decide whether an owner authorizes the derived release.

Closest-work positioning

Decentralized information-flow labels already combine policies from mutually distrusting principals, and Fabric enforces such policies across distributed computation.[1][2] Multiparty access control addresses conflicts among stakeholders of a shared object, while SecPAL provides a formal language for decentralized authorization and delegation.[3][4] Whole-system provenance records data transformations but does not by itself define approval preservation.[5] The intended gap is therefore transformation-sensitive preservation and renewal for one concrete final artifact, not generic policy conjunction, provenance capture, or distributed IFC.

Research questions

RQ1. Which owner obligations are preserved by projection, filtering, approved joins, and fixed aggregates, and which transformations require issuer-specific renewal?

RQ2. Can a checker safely authorize more useful releases than policy intersection or mandatory global renewal while preserving every owner's declared constraint?

RQ3. What is the smallest conflict or missing-evidence explanation that enables a user or owner to revise a workflow without weakening unrelated policies?

Method

1. Artifact and policy model. Represent each artifact by a digest, schema, owner set, provenance edges, and issuer-scoped obligations over fields, purposes, audiences, transformations, and validity conditions. Policies are immutable within one checking transaction.

2. Typed transformation algebra. Give each supported transform a declared semantic rule. Projection can remove obligations tied only to removed fields; filtering preserves obligations on retained records; joins combine owner constraints; fixed aggregates may discharge row-level restrictions only under explicit threshold and audience conditions.

3. Obligation propagation. Compute the obligations that survive a transformation path, retain issuer identity, and record which rule discharged or strengthened each condition. Unsupported transforms yield unknown rather than implicit permission.

4. Release checking. Bind the output digest and recipients to a permit only when every surviving obligation is satisfied. Otherwise return a minimal conflicting obligation set, missing evidence, or a renewal request addressed only to the affected issuers.

5. Conditional results. For the restricted algebra, state and prove preservation lemmas under explicit assumptions about transformation correctness and artifact binding. Mechanized checks are added where feasible; empirical evaluation does not substitute for the declared proof obligations.

Expected technical artifact

The prototype will include a compact policy language, transformation-witness format, obligation propagator, release checker, conflict explainer, and reproducible workflow fixtures. Each decision produces a receipt containing the input digests, transform chain, policy versions, recipients, discharged obligations, and unresolved conditions.

Evaluation plan

The evaluation uses workflows in which independently governed artifacts are projected, filtered, joined, and aggregated before release. Scenarios cover compatible policies, audience expansion, purpose mismatch, owner conflicts, stale approval, transformed-field removal, threshold aggregation, unsupported transforms, and evidence loss. Policies and expected outcomes are reviewed before running the checker.

Baselines are plain policy intersection, renewal after every transformation, global owner voting, and strong handwritten release rules. Primary measures are unauthorized releases, useful authorized completion, approval burden, false renewal requests, explanation size, checker latency, and policy-authoring effort. Mutation tests target artifact substitution, recipient changes, missing transforms, reordered witnesses, and stale policy snapshots.

Ablations remove issuer identity, exact output binding, provenance links, and transformation-specific rules. These tests determine whether the proposed precision comes from the claimed mechanisms or merely from a more permissive policy set.

Expected contributions and limits

Expected contributions are: (i) a restricted semantics for multi-owner obligations over transformed artifacts; (ii) a checker that returns preservation witnesses, minimal conflicts, or scoped renewal requests; and (iii) evidence about the security-utility trade-off against conservative baselines. The central success criterion is safe additional utility over global renewal, not policy-language novelty alone.

Guarantees depend on correct owner assignment, truthful transformation witnesses, faithful transform semantics, collision-resistant artifact binding, and a mediated release gate. The first version does not prove the semantics of arbitrary model-generated summaries, repair compromised hosts, or solve global revocation. If conventional decentralized label joins match the checker on all credible cases, the proposed specialization is not justified.

Selected references

[1] A. C. Myers and B. Liskov. Complete, Safe Information Flow with Decentralized Labels. IEEE Symposium on Security and Privacy, 1998.

[2] J. Liu et al. Fabric: A Platform for Secure Distributed Computation and Storage. SOSP, 2009. doi:10.1145/1629575.1629594.

[3] H. Hu, G.-J. Ahn, and J. Jorgensen. Multiparty Access Control for Online Social Networks: Model and Mechanisms. IEEE TKDE, 2013. doi:10.1109/TKDE.2012.97.

[4] M. Y. Becker, C. Fournet, and A. D. Gordon. SecPAL: Design and Semantics of a Decentralized Authorization Language. Journal of Computer Security, 2010. doi:10.3233/JCS-2009-0364.

[5] T. F. J.-M. Pasquier et al. Practical Whole-System Provenance Capture. ACM SoCC, 2017. doi:10.1145/3127479.3129249.